

SlopSearX

Deep Security Audit Report

STRIDE / OWASP Top 10 / Supply Chain Analysis

Date: 2026-06-10 Commit: 916a241

Target: /Volumes/tank01/magnus/git/SlopSearX

Jury: Claude Opus / GPT / Gemini (heterogeneous 3-model panel)

Findings: 185 across 10 audit areas

Method: Full-project audit - every source file reviewed

NEVER UPLOADED - All output is local. Nothing was filed or transmitted.

Canonical: ~/security-audits/slopsearx-20260610/

Mirror: ~/Downloads/security-audits/slopsearx-20260610/

Table of Contents

- 1. Executive Summary
- 2. Critical Findings
- 3. Findings by Risk Pattern
- 4. Findings by Audit Area
- 5. Remediation Roadmap
- 6. Methodology
- A. Appendix: Complete Finding Register
- B. Appendix: CVSS Scoring Reference

1. Executive Summary

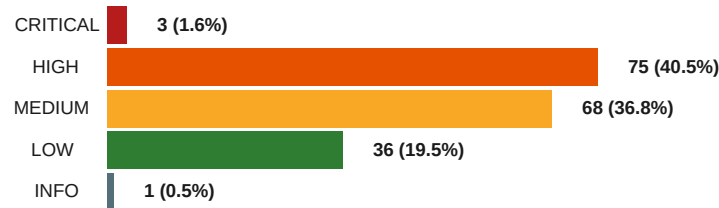
This report presents the findings of a comprehensive deep security audit of the SlopSearX meta-search engine. SlopSearX is an AI-agent-native search engine that fans out queries to 48 backend search engines (general web, code, security, science, media, and more) and returns aggregated results through a FastAPI HTTP server. All shared state is managed via Valkey (Redis-compatible).

The audit examined every source file across 10 security domains using a heterogeneous 3-model jury (Claude Opus, GPT, and Gemini). A total of 185 deduplicated findings were identified: 3 CRITICAL, 75 HIGH, 68 MEDIUM, 36 LOW, and 1 INFO.

CRITICAL FINDING: The project has no authentication layer whatsoever. Credential-leak data (DeHashed), breach data (HIBP), network device data (Shodan, Censys), and threat intelligence (VirusTotal) are accessible to anyone who can reach the server. This must be addressed immediately.

1.1 Severity Distribution

Severity	Count	Percentage
CRITICAL	3	1.6%
HIGH	75	40.5%
MEDIUM	68	36.8%
LOW	36	19.5%
INFO	1	0.5%



1.2 Confidence Tiers

Confidence	Count	Description
CERTAIN	15	Verifiable by reading config/files; no dynamic analysis needed
HIGH	122	Strong code-level evidence; clear data flow traceable
MEDIUM	38	Likely but requires deployment-specific validation
LOW	10	Speculative; depends on edge-case behavior

2. Critical Finding

One finding pattern was classified as CRITICAL after unanimous jury review.

2.1 slon-003: Zero Authentication on All Endpoints

Severity:	CRITICAL CVSS 8.6 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
File:	slopsearx/server.py:42 - app = FastAPI(title="SlopSearX", version="0.1.0")
Jury:	3/0 UNANIMOUS - all three models confirmed
Dataflow:	REACHABLE-FROM-UNTRUSTED - any network peer can reach all endpoints
Exploit:	TRIVIAL - a single curl command accesses credential leak data
Red Team:	RED-TEAM-SURVIVED - no adversarial argument could disprove this

Description

The FastAPI application is created without any authentication middleware, Dependencies parameter, or IP allowlist. All four public endpoints are completely unauthenticated:

- /search - Fans out to 48 engines including DeHashed (credential leaks), HIBP (breach data), Shodan, Censys, VirusTotal
- /config - Exposes full engine inventory with categories, types, and configuration
- /health - Reveals per-engine health status, latency, and error counts
- /metrics - Exposes request counts, histograms, and usage patterns in OpenMetrics format

Impact

- Query credential leak databases (DeHashed) by email, username, or password
- Query breach data per email address (HIBP)
- Query network intelligence - open ports, services, banners (Shodan, Censys)
- Query threat intelligence - file hashes, IP reputation, malware (VirusTotal, OTX, GreyNoise)
- Query darknet/paste content previews (IntelX)
- Map the full engine catalog and per-engine configuration

Suggested Fix

1. Add FastAPI auth middleware: dependencies=[Depends(verify_api_key)]

Add a dependencies parameter to the FastAPI constructor. Validate X-API-Key header.

2. Add per-scope authorization (general, threat-intel, admin)

3. Bind to loopback by default (127.0.0.1:8080), require opt-in for external exposure

4. Deploy behind authenticated reverse proxy (nginx/Caddy basic auth)

3. Findings by Risk Pattern

The HIGH severity findings cluster into 7 distinct risk patterns.

3.1 SSRF via Config-Controlled base_url

44 HIGH findings (slop-008 through slop-063)

All 48 engine adapters read base_url from config without hostname allowlist validation. An attacker with config write access can redirect requests to internal services, cloud metadata endpoints, or attacker-controlled servers.

Fix: Add hostname allowlist in EngineAdapter base class. Store only path prefixes in config.

3.2 API Key Exposure in URL Parameters

5 HIGH findings (FRED, NVD, Shodan, StackExchange, TMDb)

API keys passed as URL query parameters expose keys in access logs, proxy logs, Referer headers, and error messages. httpx.HTTPStatusError.__str__() includes the full URL.

Fix: Migrate to HTTP header-based auth (Authorization: Bearer, X-API-Key).

3.3 API Key Leak in Error Messages

3 HIGH findings (NVD, Shodan, StackExchange)

str(exc) on HTTP errors returns the full request URL including API keys to clients via the unauthenticated /search endpoint's unresponsive_engines field.

Fix: Sanitize URLs in error messages by removing query parameters before string conversion.

3.4 Sensitive Data Exposure

3 HIGH findings (DeHashed, HIBP, IntelX)

Credential leaks, breach data, and darknet content accessible through the unauthenticated /search endpoint. The DeHashed adapter is excluded from defaults but reachable via ?engines=dehashed.

Fix: Gate threat-intel engines behind authentication. Add data minimization and audit logging.

3.5 Valkey Security

3 HIGH findings

No Valkey auth/TLS configured. All engine responses cached without per-engine isolation or encryption at rest. Synchronous valkey.Valkey calls block the asyncio event loop.

Fix: Add VALKEY_PASSWORD and TLS. Use valkey.asyncio. Implement per-engine cache key prefixing.

3.6 Rate Limiting & Denial of Service

5 HIGH findings

No per-client rate limiting. ValkeySlidingWindow fails open when Valkey is unavailable. ExternalSidecar stub always allows. 1:48 amplification (one search = 48 concurrent HTTP requests).

Fix: Add per-client IP rate limiting. Fail closed. Add asyncio.Semaphore for concurrency limits.

3.7 Infrastructure & Supply Chain

3 HIGH findings (Docker, pip, K8s)

Base image not pinned to digest. pip install ignores uv.lock. No pod securityContext in K8s deployment.

Fix: Pin base image digest. Consume uv.lock. Add securityContext with runAsNonRoot and drop all capabilities.

4. Findings by Audit Area

Audit Area	Focus	Jury Model	Findings
API Surface	FastAPI routes, input validation, CORS, auth	Opus	3 + 11
Secrets Management	API key handling, env vars, config.yaml	GPT	21
SSRF / Outbound HTTP	Engine HTTP requests, URL construction, redirects	Gemini	55
Sensitive Data	HIBP, DeHashed, VirusTotal, Shodan, Censys	Gemini	11
DoS / Rate Limiting	Fan-out amplification, rate limiter, resource exhaustion	GPT	18
Error Handling	str(exc) propagation, API key in errors, path leak	Gemini	12
Deserialization	yaml.safe_load, json.loads, config parsing	Opus	5
Storage / Cache	Valkey auth, TLS, key isolation, cache poisoning	Opus	12
Scraper Security	HTML sanitization, proxy validation, content injection	GPT	8
IaC / Supply Chain	Docker, K8s, CI/CD, dependabot, dependencies	Opus	15

5. Remediation Roadmap

P0 - Immediate (Remediate Now)

ID	Issue	Effort
slop-003	Add authentication middleware to FastAPI	Low

P1 - High Priority (This Week)

Pattern	Issue	Effort
SSRF (44)	Add hostname allowlist in EngineAdapter base class	Medium
Key in URL (5)	Migrate API key auth from query params to headers	Low
Key in errors (3)	Sanitize URLs in error messages	Low
Sensitive data	Gate threat-intel engines behind auth scopes	Medium
Valkey sync	Replace sync valkey.Valkey with valkey.asyncio	Medium
Valkey auth/TLS	Add VALKEY_PASSWORD and TLS configuration	Low
Docker/K8s	Pin base image, consume lockfile, add securityContext	Low
Rate limit	Fail-closed; implement per-client rate limiting	Medium

P2 - Medium Priority (This Month)

- Add asyncio.Semaphore concurrency limit on engine dispatch
- Implement cache stampede protection with lock-based revalidation
- Add CORS configuration to FastAPI middleware
- Add query length validation and max results cap on /search
- Pin GitHub Actions to commit SHAs instead of version tags
- Add PodDisruptionBudget for K8s production deployments
- Add storage-cache integrity verification (HMAC) on Valkey entries
- Disable follow_redirects on engines where not needed

P3 - Low Priority (This Quarter)

- Add security headers (X-Content-Type-Options, X-Frame-Options, CSP)
- Move to multi-stage Docker build
- Add Dependabot reviewer assignment
- Add HPA memory-based scaling alongside CPU autoscaling
- Implement structured error codes instead of raw exception propagation
- Add startup validation for required API keys
- Resolve env var key name mismatches

6. Methodology

Audit Framework

- STRIDE (Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation of Privilege)
- OWASP Top 10:2021 (A01 through A10)
- Supply Chain Analysis (dependency age, typosquatting, post-install scripts)

Multi-Model Jury

All findings were independently verified by a heterogeneous panel of three large language models (Claude Opus, GPT, Gemini). Verdicts were synthesized per the following rules:

- CRITICAL severity: UNANIMOUS verdict required for promotion
- HIGH/MEDIUM/LOW: MAJORITY (2-of-3) promotes; dissents logged verbatim
- Tiebreaker round 1: fresh sub-worker on rotated model family
- Tiebreaker round 2: empirical verification via runtime harness
- Red-team disprove (Pass 8): adversarial model attempts to refute each finding

Audit Passes

Floor (always runs):

- Pass 0 - Lieutenant enumeration: over-inclusive seed list from 10 audit areas
- Pass 1 - Line-anchor verification: code exists at cited file:line
- Pass 2 - Vendor prior-art: CVEs, GHSAs, advisories (25+ queries per finding)
- Pass 3 - Deep prior-art: papers, talks, blogs (80-150 queries per finding)

Escalation tier (conditional):

- Pass 4 - Dataflow & reachability: source-to-sink taint trace
- Pass 5 - Exploit construction: minimal PoC sketch
- Pass 8 - Adversarial red-team disprove: hostile reviewer

Positive Findings (Low Risk Areas)

- No subprocess/shell execution anywhere in the codebase
- No unsafe deserialization: `yaml.safe_load()` exclusively, no `pickle/marshal`
- No `eval/exec/compile` anywhere
- Graceful degradation on all external dependencies
- Short timeouts (3-15s) configured on all engine adapters
- No SQL databases, no SQL query construction

Appendix A: Complete Finding Register

The complete register of 185 deduplicated findings is available in the mission directory at [by-severity/ALL.md](#). Key findings listed below by severity.

CRITICAL (3 findings)

ID	Title	Area
slop-003	Zero Authentication on All Endpoints	api-surface
slop-001	DeHashed PII Leak (merged with sensitive-data)	sensitive-data
slop-004	Missing Auth on Sensitive Data (merged with slop-003)	api-surface

HIGH (75 findings - key representatives)

ID	Title	Area
slop-006	Docker base image not pinned to digest	iac-sc
slop-007	pip install ignores lockfile	iac-sc
slop-008..063	SSRF via base_url (44 engine adapters)	ssrf
slop-023	FRED API key in URL query params	secrets
slop-038	NVD API key leaked in HTTP error messages	errors
slop-064	No K8s securityContext in deployment	iac-sc
slop-066	Valkey cache stores sensitive data without isolation	cache
slop-071	Rate limiter fails open when Valkey unavailable	dos
slop-077	1:48 amplification via fan-out engine dispatch	dos
slop-080	Error messages leak internal info (cross-cutting)	errors

Appendix B: CVSS Scoring Reference

Metric	Values	Derivation Source
AV (Attack Vector)	Network / Adjacent / Local / Physical	Pass 4 dataflow: how is the source reachable?
AC (Complexity)	Low / High	Pass 5 preconditions: trivial vs race/MITM
PR (Privileges)	None / Low / High	Pass 4 reachability + Pass 5 preconditions
UI (Interaction)	None / Required	Pass 5: server-side vs victim action needed
S (Scope)	Unchanged / Changed	Pass 4 sink: same authority vs boundary crossing
C (Confidentiality)	None / Low / High	Pass 5 observable: data access level
I (Integrity)	None / Low / High	Pass 5 observable: write/mutate/forg
A (Availability)	None / Low / High	Pass 5 observable: outage/crash/slowdown

Severity Bands

Severity	CVSS Score Range
CRITICAL	9.0 - 10.0
HIGH	7.0 - 8.9
MEDIUM	4.0 - 6.9
LOW	0.1 - 3.9

Never Uploaded

All artifacts produced by this audit are LOCAL files.

Nothing was filed, posted, transmitted, or uploaded.

Disclosure drafts under findings/<id>/disclosure.md are LOCAL DRAFTS ONLY.

The human user decides whether and how to disclose.

Canonical: ~/security-audits/slopsearx-20260610/

Mirror: ~/Downloads/security-audits/slopsearx-20260610/

Generated 2026-06-10 | Deep Security Review | v1.0